

CUADERNILLO DE ESTUDIO

CLASE 13

*“Continuidad de negocio, auditoría
y cierre de contenidos”*

⑩ Cuarta actividad con IA del cuatrimestre

Profesor: Mg. Ing. Rodrigo Atilio Elgueta

Unidad: Cierre de Unidad 4

Datos del/la estudiante

Nombre y apellido: _____

Grupo N.º: _____

Negocio Digital (TP): _____

Fecha: _____

Índice

1. Continuidad del negocio y recuperación ante desastres	2
1.1. Diferencia entre BCP y DRP	2
1.2. Repaso: RTO, RPO y MTD (Clase 6)	2
2. Componentes de un Plan de Continuidad	4
3. La auditoría de seguridad como mejora continua	5
3.1. Tipos de auditoría	5
3.2. El ciclo PHVA / PDCA de mejora continua	5
4. Actividad con IA: Plan de Respuesta a Incidentes	7
4.1. Paso 1: Generar el borrador con IA	7
4.2. Paso 2: Auditar el borrador contra el checklist de referencia	8
5. Reporte de auditoría (verificación crítica de la IA)	10
6. Plantilla del Plan de Respuesta a Incidentes	12
7. Cierre de Unidad 4 y del cuatrimestre	14
8. Próximos pasos: Clases 14 y 15	15
9. Glosario de la Clase 13	17
10. Espacio para notas y preparación del TP final	17

1. Continuidad del negocio y recuperación ante desastres

En la Clase 12 vimos cómo gestionar un **incidente** mientras ocurre. Hoy damos el siguiente paso: ¿cómo nos aseguramos de que el negocio **sobreviva** al incidente y pueda volver a operar?

Definición

La **Continuidad del Negocio (BCP - Business Continuity Plan)** es el conjunto de procesos y procedimientos diseñados para garantizar que las funciones críticas de una organización puedan continuar o reanudarse rápidamente tras una interrupción significativa.

Definición

El **Plan de Recuperación ante Desastres (DRP - Disaster Recovery Plan)** es un subconjunto del BCP, enfocado específicamente en la recuperación de los **sistemas de información y tecnología** tras un desastre (natural, humano o técnico).

1.1 Diferencia entre BCP y DRP

	BCP (Continuidad del Negocio)	DRP (Recuperación ante Desastres)
Alcance	Todo el negocio: personas, procesos, físico, tecnológico.	Sólo los sistemas de información y tecnología.
Pregunta clave	¿Cómo sigue operando el negocio?	¿Cómo recuperamos los sistemas?
Ejemplo	Mudar la atención al cliente a una oficina alternativa tras un incendio.	Restaurar la base de datos desde el backup tras un ransomware.

Regla práctica

Un buen BCP **incluye** un DRP. Para un negocio digital, el DRP suele ser la pieza más crítica del BCP porque la operación depende casi 100 % de sistemas tecnológicos.

1.2 Repaso: RTO, RPO y MTD (Clase 6)

Estos tres indicadores, que vimos en el BIA, son la **columna vertebral** del DRP:

Sigla	Significado	Impacto en el DRP
MTD	Máximo tiempo tolerable de interrupción	Define cuánto puede estar caído un proceso antes de que el negocio muera.
RTO	Objetivo de tiempo de recuperación	Define qué tan rápido deben restaurarse los sistemas (guía la infraestructura).
RPO	Pérdida máxima de datos aceptable	Define la frecuencia mínima de backups y la arquitectura de replicación.

- **Proceso crítico:** Pasarela de pago.
- **MTD:** 2 horas (más que eso, se pierden ventas y confianza).
- **RTO:** 1 hora (los sistemas deben estar operativos en 60 min).
- **RPO:** 5 minutos (no se puede perder ninguna transacción).

Estos números definen **qué infraestructura necesita el negocio**: backups cada 5 min, replicación en dos regiones, failover automático, etc.

2. Componentes de un Plan de Continuidad

Un BCP/DRP profesional tiene, como mínimo, estas piezas:

Componente	¿Qué incluye?
1. Alcance y objetivos	¿Qué procesos cubre el plan? ¿Cuáles son las prioridades?
2. Roles y responsabilidades	¿Quién declara la crisis? ¿Quién ejecuta cada parte del plan?
3. Criterios de activación	¿Qué eventos disparan el plan? (ej. caída > 1h, ransomware confirmado, desastre natural)
4. Plan de comunicación	¿A quién y cómo se informa? (empleados, clientes, proveedores, reguladores, prensa)
5. Procedimientos de recuperación	Pasos técnicos detallados para restaurar cada sistema.
6. Sitio alternativo	Si el sitio principal no está disponible, ¿desde dónde se opera?
7. Pruebas y simulacros	¿Cada cuánto se prueba el plan? ¿Cómo se mejora?
8. Mantenimiento del plan	¿Quién lo actualiza? ¿Cada cuánto?

El plan que nunca se prueba, no es un plan

Muchas empresas redactan un plan de continuidad y lo guardan en un cajón. El día que ocurre el desastre real, nadie sabe dónde está ni cómo usarlo. Un plan válido se **prueba al menos una vez al año** con un simulacro (como la Junta de Crisis de la Clase 12).

3. La auditoría de seguridad como mejora continua

Hasta ahora vimos cómo construir un programa de seguridad (Unidades 1 a 4). Pero, ¿cómo sabemos que funciona, que se cumple y que mejora con el tiempo? La respuesta es la **auditoría**.

Definición

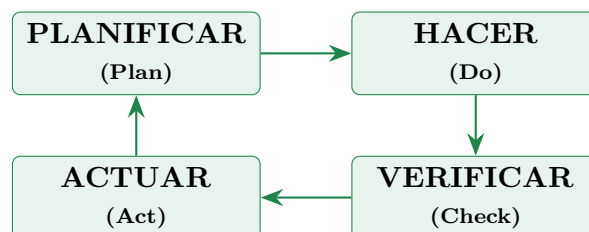
Una **auditoría de seguridad de la información** es un examen sistemático, independiente y documentado para determinar si las actividades y resultados de seguridad cumplen con los planes establecidos, y si estos se implementan eficazmente y son adecuados para alcanzar los objetivos.

3.1 Tipos de auditoría

Tipo	Características
Interna (primera parte)	La realiza la propia organización (equipo interno o auditoría interna). Objetivo: mejorar procesos.
Externa (segunda parte)	La realiza un cliente o partner con interés en la organización. Objetivo: verificar cumplimiento contractual.
De certificación (tercera parte)	La realiza un organismo independiente. Objetivo: certificar cumplimiento de un estándar (ej. ISO 27001).

3.2 El ciclo PHVA / PDCA de mejora continua

La auditoría alimenta el ciclo clásico de mejora continua que sostiene ISO 27001:



Fase	¿Qué se hace?
Planificar	Definir políticas, riesgos, controles.
Hacer	Implementar los controles.
Verificar	Auditar, medir, monitorear. (¡Esto es la auditoría!)
Actuar	Corregir y mejorar lo que no funcionó.

Una cultura sana ve la auditoría como una **herramienta de mejora**, no como una inspección punitiva. Las organizaciones maduras buscan auditorías porque les revelan dónde mejorar antes de que un atacante o un incidente lo hagan por ellas.

4. Actividad con IA: Plan de Respuesta a Incidentes

Esta es la **cuarta y última** actividad con IA del cuatrimestre. Consolida todo lo aprendido: el Plan de Respuesta a Incidentes es el **Entregable 6** de su TP Integrador, y debe estar verificado por ustedes antes de la entrega final.

4.1 Paso 1: Generar el borrador con IA

Consigna: En grupos, usen una IA generativa (ChatGPT, Claude, Gemini, etc.) para producir un **borrador de Plan de Respuesta a Incidentes** para el negocio digital de su TP Integrador.

Prompt sugerido:

“Actúa como un consultor senior en ciberseguridad y continuidad de negocio. Redactá un Plan de Respuesta a Incidentes (IRP) para [TIPO DE NEGOCIO DIGITAL] con [TAMAÑO / EMPLEADOS / PRODUCTO PRINCIPAL]. El plan debe incluir: alcance, roles (Junta de Crisis), criterios de activación, fases de respuesta (detección, contención, erradicación, recuperación, lecciones aprendidas), plan de comunicación interna y externa, y procedimientos básicos ante los tres escenarios más probables: (1) ransomware, (2) filtración de datos de clientes, (3) caída prolongada del servicio principal. Basate en buenas prácticas de NIST SP 800-61 e ISO/IEC 27001.”

Entrega: el borrador generado (puede pegarse en la Sección 6 de este cuadernillo o en un documento aparte).

4.2 Paso 2: Auditar el borrador contra el checklist de referencia

A continuación, el **checklist de referencia** basado en **NIST SP 800-61** (guía de manejo de incidentes de seguridad) e **ISO/IEC 27001** (Anexo A, control A.16 Gestión de Incidentes). Usen este checklist para auditar el borrador que generó la IA.

#	Punto a verificar	Sí	No
Estructura general			
1	El plan tiene un alcance claramente definido (qué sistemas y procesos cubre).	☐	☐
2	Hay una lista clara de roles y responsabilidades (Junta de Crisis, TI, Legal, Comunicaciones).	☐	☐
3	Existen criterios de activación (¿qué eventos disparan el plan?).	☐	☐
Fases de respuesta (NIST SP 800-61)			
4	El plan cubre las 4 fases: Detección, Contención, Erradicación, Recuperación .	☐	☐
5	Incluye una fase de Lecciones Aprendidas posterior al incidente.	☐	☐
6	Define procedimientos para preservar evidencia forense.	☐	☐
Comunicación (ISO 27001 A.16.1.2)			
7	Hay un plan de comunicación interna (empleados).	☐	☐
8	Hay un plan de comunicación externa (clientes, prensa, reguladores).	☐	☐
9	Se especifican los plazos legales de notificación (Ley 25.326, GDPR si aplica).	☐	☐
Escenarios específicos			
10	El plan incluye procedimientos para ransomware .	☐	☐
11	El plan incluye procedimientos para filtración de datos .	☐	☐
12	El plan incluye procedimientos para caída prolongada del servicio .	☐	☐
Mejora continua (ISO 27001)			
13	El plan define pruebas y simulacros periódicos .	☐	☐
14	Existe una frecuencia definida de revisión y actualización del plan.	☐	☐
Conexión con la continuidad (DRP/BCP)			
15	Se define el RTO (objetivo de tiempo de recuperación) de los sistemas críticos.	☐	☐
16	Se define el RPO (pérdida máxima de datos) de los sistemas críticos.	☐	☐

5. Reporte de auditoría (verificación crítica de la IA)

Este reporte es el **Anexo “Uso de IA”** de su TP Integrador. Debe mostrar evidencia real de pensamiento crítico, no solo una copia acrítica de la salida de la IA.

6. Plantilla del Plan de Respuesta a Incidentes

Entrega obligatoria de hoy

Este es el **Entregable 6 del TP Integrador**. Debe entregarse al final de esta clase como **avance obligatorio** (aprobado/desaprobado, condiciona la regularidad). La versión final se incorpora al dossier que defienden en la Clase 15.

PLAN DE RESPUESTA A INCIDENTES

[Nombre del Negocio Digital] — Versión 1.0

1. Alcance y objetivos

2. Roles y Junta de Crisis

3. Criterios de activación

4. Fases de respuesta (NIST SP 800-61)

Detección: _____

Contención: _____

Erradicación: _____

Recuperación: _____

Lecciones aprendidas: _____

5. Plan de comunicación

Interna (empleados): _____

Externa (clientes, prensa): _____

Reguladores (AAIP / GDPR): _____

6. Escenarios específicos

Escenario A — Ransomware: _____

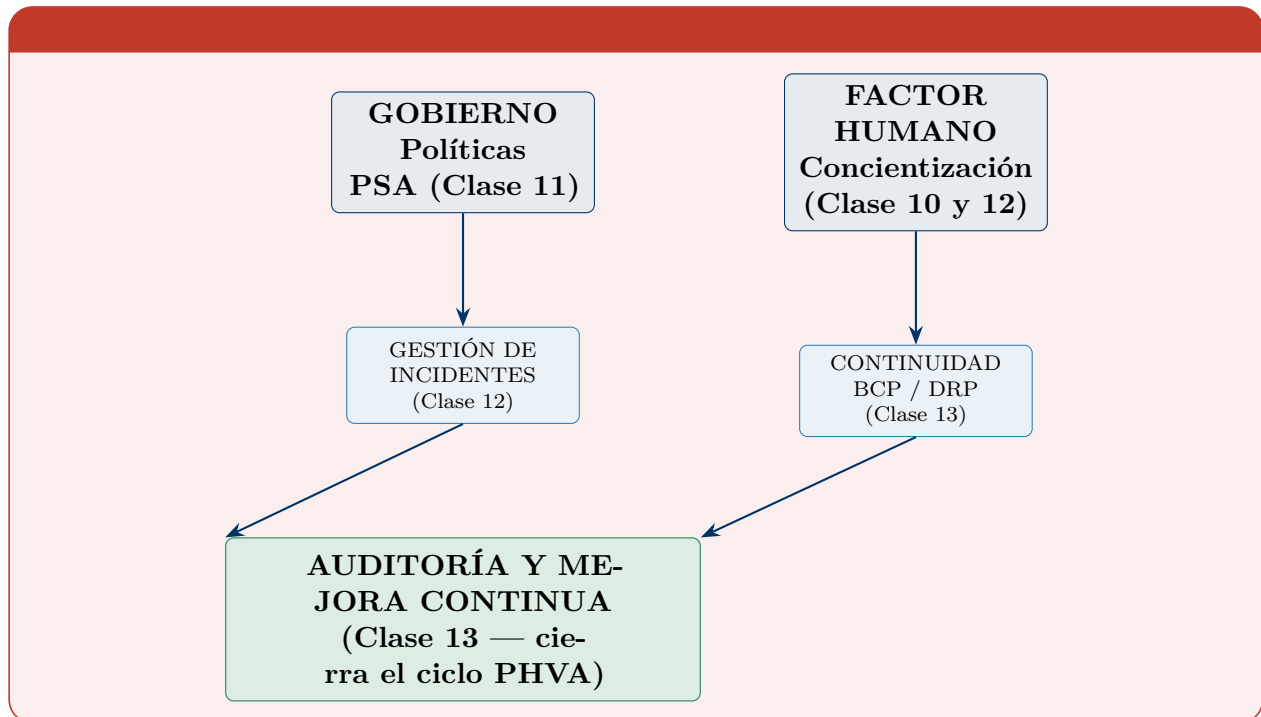
Escenario B — Filtración de datos de clientes: _____

Escenario C — Caída prolongada del servicio principal: _____

7. RTO, RPO y MTD de los procesos críticos**8. Pruebas, simulacros y mantenimiento**

7. Cierre de Unidad 4 y del cuatrimestre

Con esta clase completamos el tablero de la **Unidad 4: Gobierno de la Seguridad, Factor Humano, Incidentes y Continuidad**.



Lo que nos llevamos de la Unidad 4

- Construir un **gobierno** de la seguridad (políticas, normas, procedimientos, roles).
- Redactar una **Política de Seguridad Aceptable** realista (Clase 11 / Parcial 2).
- Diseñar campañas de **concientización** y simulacros de phishing (Clase 10).
- Gestionar una **crisis** en tiempo real con roles de Junta (Clase 12).
- Planificar la **continuidad del negocio** y recuperación ante desastres (Clase 13).
- Usar la **auditoría** como herramienta de mejora continua.

8. Próximos pasos: Clases 14 y 15

Clase	¿Qué haremos?
Clase 14 (Taller integración) Coevaluación cruzada entre grupos con rúbrica breve (ensayo general). Entrega de la versión pre-final del TP Integrador.	Mentoría rotativa: el docente revisa el avance de cada grupo.
Clase 15 (Defensa final) 10 minutos de exposición + 5 minutos de preguntas individuales por grupo. Encuesta de satisfacción final. Nota 1-10, aprueba con 4 (reemplaza el examen final).	Presentación final de los 4-5 grupos ante el docente y evaluador invitado.

Antes de irse, revisen el avance de su TP Integrador y marquen qué les falta:

Entregable del TP	Listo	Falta
1. Mapa de activos y análisis CID	☐	☐
2. Matriz de riesgos + BIA + controles	☐	☐
3. Evaluación de seguridad en la nube	☐	☐
4. Cumplimiento normativo y política de privacidad	☐	☐
5. Política de Seguridad Aceptable (PSA)	☐	☐
6. Plan de Respuesta a Incidentes (hoy)	☐	☐
7. Anexo “Uso de IA”	☐	☐

9. Glosario de la Clase 13

Término	Definición en una línea
BCP (Business Continuity Plan)	Plan para que el negocio siga operando tras una interrupción.
DRP (Disaster Recovery Plan)	Plan para recuperar los sistemas de información tras un desastre.
RTO	Objetivo de tiempo de recuperación de un sistema.
RPO	Pérdida máxima de datos aceptable (define frecuencia de backup).
MTD	Máximo tiempo tolerable de interrupción de un proceso.
Auditoría de seguridad	Examen sistemático e independiente de los controles de seguridad.
PHVA / PDCA	Ciclo Planificar-Hacer-Verificar-Actuar de mejora continua.
ISO/IEC 27001	Norma internacional de Sistemas de Gestión de Seguridad de la Información.
NIST SP 800-61	Guía del NIST para el manejo de incidentes de seguridad.
Simulacro	Prueba controlada de un plan de respuesta o continuidad.

10. Espacio para notas y preparación del TP final

Usá este espacio para anotar hallazgos de la auditoría al borrador de IA, dudas pendientes para la mentoría de la Clase 14, o ideas para la defensa oral de la Clase 15.